

SOC L1 Interview Guide — 200 Questions

Complete Q&A Reference for SOC Analyst Interview Prep

Section 1: Original 100 Questions (Q1–Q100)

Q1. What is the role of a SOC L1 Analyst?

Ans: A SOC L1 Analyst monitors alerts and logs, identifies potential threats, and escalates true incidents to the next level. They are the first line of defense in detecting and responding to security events.

Example: *Reviewing a SIEM alert for multiple failed logins and escalating it if it looks suspicious.*

Q2. What is SIEM?

Ans: SIEM (Security Information and Event Management) collects and analyzes logs from various sources to detect and respond to security incidents.

Example: *Tools like Splunk or QRadar help correlate events and generate alerts.*

Q3. What is an alert?

Ans: An alert is a notification generated by security tools when a suspicious activity or policy violation is detected.

Example: *An alert for an unusual login attempt from a new country.*

Q4. What is the difference between an alert and an incident?

Ans: An alert is a potential issue, while an incident is a confirmed security event that requires action.

Example: *An alert for malware download may become an incident after analysis.*

Q5. What is a false positive?

Ans: A false positive is an alert that appears suspicious but is actually benign.

Example: *An alert for admin login during a maintenance window.*

Q6. What is log analysis?

Ans: Log analysis is the process of reviewing and interpreting logs to identify suspicious activities or security threats.

Example: *Checking firewall logs for blocked IP addresses.*

Q7. What are common log sources?

Ans: Common log sources include firewall, IDS/IPS, EDR, servers, applications, and network devices.

Example: *Windows Event Logs, Syslog, VPN logs.*

Q8. What is IOC?

Ans: IOC (Indicator of Compromise) is any evidence that indicates a system may be compromised.

Example: *Malicious IP, suspicious domain, or strange file hash.*

Q9. What is IP reputation?

Ans: IP reputation refers to the trust level of an IP address based on its past behavior.

Example: *Blocking an IP known for malicious activities.*

Q10. What is phishing?

Ans: Phishing is a social engineering attack where attackers trick users into revealing sensitive information.

Example: Fake emails asking for login credentials.

Q11. What is malware?

Ans: Malware is malicious software designed to harm or exploit systems.

Example: Virus, Trojan, ransomware, spyware.

Q12. What is ransomware?

Ans: Ransomware is a type of malware that locks data and demands payment for decryption.

Example: WannaCry, Locky.

Q13. What is a firewall?

Ans: A firewall monitors and controls incoming and outgoing network traffic based on security rules.

Example: Blocking unauthorized access to specific ports.

Q14. What is IDS and IPS?

Ans: IDS (Intrusion Detection System) detects threats, while IPS (Intrusion Prevention System) can block or prevent them.

Example: Snort (IDS), Suricata (IDS/IPS).

Q15. What is VPN?

Ans: VPN (Virtual Private Network) creates a secure connection over the internet.

Example: Remote employees accessing company network securely.

Q16. What is brute force attack?

Ans: Brute force attack is a method to gain access by trying multiple passwords or keys.

Example: Trying many password combinations to log in.

Q17. What is a port scan?

Ans: Port scan is used to find open ports on a target system.

Example: Using Nmap to scan open ports.

Q18. What is hashing?

Ans: Hashing converts data into a fixed-size string, which is unique to that data.

Example: SHA-256 hash used to verify file integrity.

Q19. What is a honeypot?

Ans: A honeypot is a decoy system set up to attract attackers and analyze their behavior.

Example: Deploying a fake login page to capture attacker credentials.

Q20. What is threat intelligence?

Ans: Threat intelligence is information about potential or current threats used to make informed security decisions.

Example: Using threat feeds to block malicious IPs.

Q21. What is SQL Injection?

Ans: SQL Injection is an attack where attackers insert malicious SQL queries into input fields to manipulate a database.

Example: An attacker enters ' OR '1'='1' in a login form to bypass authentication.

Q22. What is XSS (Cross-Site Scripting)?

Ans: XSS is an attack where malicious scripts are injected into trusted websites and run in the browser of other users.

Example: An attacker posts a comment with `<script>alert('XSS')</script>` on a forum.

Q23. What is DDoS Attack?

Ans: DDoS (Distributed Denial of Service) attack overwhelms a target server with massive traffic, making it unavailable.

Example: Attackers use a botnet to flood a website with traffic, causing downtime.

Q24. What is a Zero-Day Exploit?

Ans: A Zero-Day exploit targets a vulnerability that is unknown to the vendor and has no available patch.

Example: Attackers exploit a new Windows vulnerability before Microsoft releases a fix.

Q25. What is Threat Intelligence?

Ans: Threat Intelligence is information about potential or current threats used to make informed security decisions.

Example: Using indicators from threat feeds to block malicious IPs.

Q26. What is a Security Incident?

Ans: A Security Incident is any event that compromises the confidentiality, integrity, or availability of a system.

Example: Unauthorized access to a server is a security incident.

Q27. What is Incident Response?

Ans: Incident Response is the process of detecting, analyzing, containing, eradicating, and recovering from security incidents.

Example: Isolating an infected host, removing malware, and restoring systems.

Q28. What is a Playbook in SOC?

Ans: A Playbook is a documented set of procedures for handling specific types of security incidents.

Example: A phishing incident playbook with steps to investigate and remediate.

Q29. What is an IOC (Indicator of Compromise)?

Ans: An IOC is evidence that an attacker has compromised a system or network.

Example: A malicious IP address, file hash, or suspicious domain.

Q30. What is a False Positive?

Ans: A False Positive is an alert that is incorrectly identified as a threat.

Example: An IDS alert triggered by legitimate network activity.

Q31. What is a False Negative?

Ans: A False Negative is a real threat that is not detected by security controls.

Example: Malware that bypasses antivirus and goes undetected.

Q32. What is Log Retention?

Ans: Log Retention is the process of storing logs for a specific period for compliance, and auditing.

Example: Keeping firewall logs for 90 days for investigation.

Q33. What is UEBA?

Ans: UEBA (User and Entity Behavior Analytics) uses machine learning to detect abnormal behavior of users or entities.

Example: Detecting a user logging in from new locations at unusual times.

Q34. What is EDR?

Ans: EDR (Endpoint Detection and Response) monitors endpoints for threats and helps in detection, investigation, and response.

Example: EDR tool alerts when ransomware behavior is detected.

Q35. What is a Honeypot?

Ans: A Honeypot is a decoy system set up to attract attackers and analyze their behavior.

Example: Deploying a fake login page to capture attacker credentials.

Q36. What is a Sandbox?

Ans: A Sandbox is an isolated environment used to safely execute suspicious files and observe their behavior.

Example: Running an unknown file in a sandbox to check for malware.

Q37. What is Data Exfiltration?

Ans: Data Exfiltration is the unauthorized transfer of data from a compromised system to an external location.

Example: An attacker stealing customer data and sending it to their server.

Q38. What is Lateral Movement?

Ans: Lateral Movement is when an attacker moves within a network to access more systems.

Example: Using stolen credentials to access another internal server.

Q39. What is Privilege Escalation?

Ans: Privilege Escalation is when an attacker gains higher access levels than originally permitted.

Example: A user exploit to gain admin privileges.

Q40. What is Patch Management?

Ans: Patch Management is the process of identifying, testing, and applying updates to fix vulnerabilities.

Example: Applying Windows security patches to prevent exploits.

Q41. What is a SOC Tier model (L1, L2, L3)?

Ans: The SOC tier model divides analysts by experience and responsibility — L1 handles initial alert triage and monitoring, L2 performs deeper investigation and response, and L3 handles advanced threat hunting and forensics.

Example: An L1 analyst triages an alert, escalates it to L2 for deeper investigation, which may further escalate to L3 for forensic analysis.

Q42. What is an attack surface?

Ans: An attack surface is the total sum of all possible entry points an attacker could use to access or exploit a system.

Example: Open ports, exposed web apps, and unpatched software all add to an organization's attack surface.

Q43. What is a CVE?

Ans: A CVE (Common Vulnerabilities and Exposures) is a publicly disclosed, uniquely identified software or hardware vulnerability.

Example: CVE-2021-44228 refers to the Log4Shell vulnerability in Log4j.

Q44. What is a CVSS score?

Ans: A CVSS (Common Vulnerability Scoring System) score rates the severity of a vulnerability on a scale from 0 to 10 based on factors like exploitability and impact.

Example: A CVE with a CVSS score of 9.8 is considered critical and needs urgent patching.

Q45. What is the difference between vulnerability scanning and penetration testing?

Ans: Vulnerability scanning is an automated process that identifies known weaknesses, while penetration testing is a manual, simulated attack to actively exploit weaknesses and assess real-world impact.

Example: Nessus performs a vulnerability scan; a pentester manually exploits a found vulnerability to demonstrate impact.

Q46. What is a man-in-the-middle (MITM) attack?

Ans: A MITM attack occurs when an attacker secretly intercepts and possibly alters communication between two parties who believe they are communicating directly.

Example: An attacker intercepting traffic on an unsecured public Wi-Fi network to steal login credentials.

Q47. What is ARP spoofing?

Ans: ARP spoofing is an attack where an attacker sends fake ARP messages to associate their MAC address with another device's IP address, enabling traffic interception.

Example: An attacker poisoning the ARP table to redirect traffic intended for the gateway through their own machine.

Q48. What is a watering hole attack?

Ans: A watering hole attack involves compromising a website that a target group frequently visits, then infecting visitors with malware.

Example: Attackers compromising an industry forum frequently visited by employees of a target company.

Q49. What is spear phishing?

Ans: Spear phishing is a targeted phishing attack aimed at a specific individual or organization, often using personalized information to appear credible.

Example: An email impersonating a CEO, addressed to a specific finance employee, requesting an urgent wire transfer.

Q50. What is whaling?

Ans: Whaling is a type of spear phishing that specifically targets high-profile individuals such as executives or senior management.

Example: An attacker crafting a fake legal notice email targeted directly at a company's CFO.

Q51. What is business email compromise (BEC)?

Ans: BEC is a scam where attackers compromise or spoof a business email account to trick employees into transferring funds or sensitive data.

Example: An attacker spoofing a vendor's email to redirect an invoice payment to a fraudulent bank account.

Q52. What is typosquatting?

Ans: Typosquatting involves registering domain names that are slight misspellings of legitimate websites to trick users or capture mistyped traffic.

Example: Registering 'gooogle.com' to catch users who mistype the real domain.

Q53. What is a supply chain attack?

Ans: A supply chain attack compromises a trusted third-party vendor or software component to gain access to the actual target organization.

Example: The SolarWinds attack, where attackers compromised software updates to infiltrate downstream customers.

Q54. What is an insider threat?

Ans: An insider threat is a security risk that originates from someone within the organization, such as an employee, contractor, or partner, who misuses their access.

Example: A disgruntled employee exfiltrating confidential data before resigning.

Q55. What is a man trap or tailgating in physical security?

Ans: Tailgating is when an unauthorized person follows an authorized person through a secured door without proper credentials.

Example: Someone walking in behind an employee who badges into a secure office.

Q56. What is multi-factor authentication (MFA)?

Ans: MFA requires users to verify their identity using two or more independent factors, such as something they know, have, or are.

Example: Logging in with a password (something you know) plus a fingerprint scan (something you are).

Q57. What is single sign-on (SSO)?

Ans: SSO allows a user to authenticate once and gain access to multiple connected applications without logging in separately to each.

Example: An employee logging into one portal that grants access to email, HR, and internal tools simultaneously.

Q58. What is the principle of least privilege?

Ans: The principle of least privilege states that users and systems should only be granted the minimum access necessary to perform their required functions.

Example: A helpdesk employee given read-only access to ticketing systems instead of full admin rights.

Q59. What is defense in depth?

Ans: Defense in depth is a security strategy that uses multiple layers of controls so that if one layer fails, others still provide protection.

Example: Combining firewalls, endpoint protection, IDS, and user training rather than relying on a single defense.

Q60. What is the CIA triad?

Ans: The CIA triad represents the three core principles of information security: Confidentiality, Integrity, and Availability.

Example: Encrypting data protects confidentiality; checksums protect integrity; backups support availability.

Q61. What is a brute force login attack?

Ans: A brute force login attack is when an attacker tries many username and password combinations to gain access.

Example: Using a tool like Hydra to guess RDP login credentials.

Q62. What is session hijacking?

Ans: Session hijacking is an attack where an attacker takes over a valid user session to gain unauthorized access.

Example: Stealing a session cookie from a user on a public Wi-Fi.

Q63. What is EPP?

Ans: EPP (Endpoint Protection Platform) is a solution that protects endpoints from malware, exploits and other threats.

Example: Microsoft Defender for Endpoint.

Q64. What is the kill chain?

Ans: The kill chain is a model that describes the steps attackers go through to compromise a target.

Example: Reconnaissance, Weaponization, Delivery, Exploitation, Installation, C2, Actions on Objectives.

Q65. What is a botnet?

Ans: A botnet is a network of infected computers controlled by an attacker to perform malicious activities.

Example: Using a botnet to launch a DDoS attack.

Q66. What is DNS spoofing?

Ans: DNS spoofing is an attack where a fake DNS response is sent to redirect users to a malicious site.

Example: Redirecting a user from bank.com to fake-bank.com.

Q67. What is file integrity monitoring (FIM)?

Ans: FIM monitors changes to critical files and alerts when unauthorized modifications occur.

Example: Alert when the hosts file is modified.

Q68. What is a rootkit?

Ans: A rootkit is malware that hides its presence by modifying the operating system.

Example: Hiding processes, files, or registry keys.

Q69. What is data exfiltration?

Ans: Data exfiltration is the unauthorized transfer of data from a system to an external location.

Example: Copying customer data and sending it to an attacker's server.

Q70. What is a C2 server?

Ans: A C2 (Command and Control) server is used by attackers to remotely control infected machines.

Example: Malware beacons to a C2 server to receive commands.

Q71. What is port forwarding?

Ans: Port forwarding is a technique to redirect traffic from one port to another device on a private network.

Example: Forwarding external port 3389 to an internal RDP server.

Q72. What is shadow IT?

Ans: Shadow IT refers to the use of unauthorized applications or devices within an organization.

Example: Employees using personal Dropbox to store company files.

Q73. What is a vulnerability assessment?

Ans: A vulnerability assessment is the process of identifying, quantifying and prioritizing vulnerabilities in systems.

Example: Using Nessus to scan servers for missing patches.

Q74. What is threat hunting?

Ans: Threat hunting is the proactive search for threats that evade existing security controls.

Example: Hunting for suspicious PowerShell activity in logs.

Q75. What is lateral movement?

Ans: Lateral movement is when an attacker moves within a network to access more systems.

Example: Using stolen credentials to access another internal server.

Q76. What is a macro virus?

Ans: A macro virus is malware written in macro language that infects documents or files.

Example: *Malicious macro in an Excel file that runs when opened.*

Q77. What is drive-by download?

Ans: Drive-by download is when malware is downloaded silently when a user visits a compromised website.

Example: *Visiting a malicious site that installs malware automatically.*

Q78. What is log correlation?

Ans: Log correlation is the process of analyzing logs from multiple sources to identify potential threats.

Example: *Correlating firewall, IDS and endpoint logs to detect an attack.*

Q79. What is a whitelisting?

Ans: Whitelisting allows only approved applications or users to run or access systems.

Example: *Allowing only approved apps using AppLocker.*

Q80. What is a security orchestration tool?

Ans: A security orchestration tool automates and coordinates responses to security incidents.

Example: *SOAR tools like Splunk Phantom or Microsoft Sentinel Playbooks.*

Q81. What is a vulnerability vs exploit?

Ans: A vulnerability is a weakness in a system, while an exploit is code or technique that takes advantage of that weakness.

Example: *A missing patch is a vulnerability; using it to gain access is an exploit.*

Q82. What is network segmentation?

Ans: Network segmentation is dividing a network into smaller segments to limit access and contain threats.

Example: *Separating HR, Finance and Guest Wi-Fi on different VLANs.*

Q83. What is an IPS?

Ans: IPS (Intrusion Prevention System) monitors network traffic and actively blocks malicious activities.

Example: *Blocking a port scan in real-time to prevent unauthorized access.*

Q84. What is two-factor authentication?

Ans: 2FA adds an extra layer of security by requiring two types of verification.

Example: *Password + OTP sent to your mobile during login.*

Q85. What is a jump server?

Ans: A jump server is a secure intermediary host used to access other servers in a restricted network.

Example: *Admins connect to jump server first, then access internal servers.*

Q86. What is DLP?

Ans: DLP (Data Loss Prevention) prevents sensitive data from leaving the organization.

Example: *Blocking users from copying confidential files to USB drives.*

Q87. What is a hash?

Ans: A hash is a fixed-size string generated from data using a hashing algorithm.

Example: *SHA-256 hash is used to verify file integrity.*

Q88. What is a certificate?

Ans: A certificate (SSL/TLS) verifies the identity of a website or server and enables encrypted communication.

Example: The padlock in your browser when visiting https websites.

Q89. What is port 3389 used for?

Ans: Port 3389 is used by Remote Desktop Protocol (RDP) to connect to a remote system.

Example: Attackers try to brute force RDP login on port 3389.

Q90. What is the purpose of antivirus?

Ans: Antivirus detects, prevents and removes malware from systems.

Example: Windows Defender scanning files to remove a virus.

Q91. What is a security incident?

Ans: A security incident is any event that compromises confidentiality, integrity or availability of data.

Example: Unauthorized access to a database is a security incident.

Q92. What is the difference between IDS and IPS?

Ans: IDS detects suspicious activity and alerts, while IPS not only detects but also blocks it.

Example: IDS alerts on a SQL injection; IPS blocks the malicious request.

Q93. What is a honeynet?

Ans: A honeynet is a network of decoy systems used to detect, divert and analyze attacker behavior.

Example: Deployed in DMZ to attract attackers and study their actions.

Q94. What is secure coding?

Ans: Secure coding is the practice of writing code that prevents vulnerabilities.

Example: Validating user input to prevent SQL injection.

Q95. What is backup and why is it important?

Ans: Backup is the process of copying data to restore it in case of loss or corruption.

Example: Daily backups help recover data after ransomware attack.

Q96. What is a phishing kit?

Ans: A phishing kit is a set of tools and templates used by attackers to create fake login pages.

Example: Used to steal credentials by mimicking legitimate websites.

Q97. What is the OSI model?

Ans: OSI model (Open Systems Interconnection) is a 7-layer framework that standardizes network communication.

Example: From Physical layer (cables) to Application layer (HTTP/FTP).

Q98. What is log retention?

Ans: Log retention is the process of storing logs for a specific period for compliance and investigation.

Example: Keeping firewall logs for 90 days.

Q99. What is social engineering?

Ans: Social engineering is manipulating people into divulging confidential information.

Example: An attacker calls pretending to be IT support to get your password.

Q100. What is the goal of a SOC?

Ans: The goal of a SOC (Security Operations Center) is to monitor, detect, analyze and respond to security threats 24/7.

Example: Detecting a brute force attack and blocking the attacker IP.

Section 2: Additional 100 Questions (Q101–Q200)

Q101. What is DHCP and why is it important?

Ans: DHCP (Dynamic Host Configuration Protocol) automatically assigns IP addresses, subnet masks, gateways, and DNS settings to devices on a network. It is important because it saves administrative effort and prevents IP conflicts.

Example: A laptop joining office Wi-Fi automatically receives an IP address from the DHCP server.

Q102. What is SSL/TLS?

Ans: SSL/TLS are cryptographic protocols that encrypt data transmitted between a client and server, ensuring confidentiality and integrity of communication.

Example: HTTPS websites use TLS to encrypt login credentials sent to a server.

Q103. What tools are commonly used for port scanning?

Ans: Common port scanning tools include Nmap, Masscan, Angry IP Scanner, and Netcat.

Example: Running 'nmap -sV target_ip' to identify open ports and running services.

Q104. What is the difference between monitoring and threat hunting?

Ans: Monitoring is reactive — watching alerts generated by existing tools — while threat hunting is proactive, manually searching for hidden threats that evaded detection.

Example: Monitoring catches a known malware signature; threat hunting finds an attacker using legitimate tools (living-off-the-land) that no alert triggered on.

Q105. What is an IOC?

Ans: An IOC (Indicator of Compromise) is forensic evidence such as a file hash, IP address, domain, or registry key that suggests a system has been breached.

Example: A known malicious file hash found on an endpoint confirms compromise.

Q106. How do you prioritize alerts?

Ans: Alerts are prioritized based on severity, asset criticality, confidence level, and potential business impact — critical systems and high-confidence alerts are handled first.

Example: A confirmed ransomware alert on a domain controller is prioritized over a low-severity failed login on a test machine.

Q107. What KPIs are important for a SOC?

Ans: Important SOC KPIs include Mean Time to Detect (MTTD), Mean Time to Respond (MTTR), number of false positives, alert volume, and incident closure rate.

Example: Reducing MTTD from 2 hours to 30 minutes shows improved detection efficiency.

Q108. What is log correlation?

Ans: Log correlation is analyzing logs from multiple sources together to identify patterns that indicate an attack, which a single log source might miss.

Example: Correlating a failed VPN login with a successful login from a new country minutes later.

Q109. Why is log retention important?

Ans: Log retention ensures historical data is available for investigations, compliance audits, and identifying the full timeline of an incident.

Example: Retaining 90 days of logs helps trace how an attacker gained initial access weeks earlier.

Q110. Explain a correlation rule you have created.

Ans: A correlation rule combines multiple conditions across log sources to trigger an alert only when a specific suspicious pattern occurs, reducing noise from single isolated events.

Example: A rule that triggers only when 5+ failed logins are followed by a successful login from the same source IP within 10 minutes, indicating a likely brute-force success.

Q111. What Event IDs indicate account creation?

Ans: Windows Event ID 4720 indicates that a new user account was created.

Example: Event ID 4720 appearing for an unexpected account on a domain controller may indicate unauthorized account creation.

Q112. What is a Registry Run Key?

Ans: A Registry Run Key is a Windows registry location that automatically launches programs at user login, often abused by malware for persistence.

Example: Malware adding itself to HKCU\Software\Microsoft\Windows\CurrentVersion\Run to survive reboots.

Q113. What indicators suggest credential dumping?

Ans: Indicators include access to LSASS process memory, use of tools like Mimikatz, unusual access to the SAM database, and Event ID 4656/4663 on sensitive files.

Example: An EDR alert showing lsass.exe being accessed by an unrecognized process.

Q114. What is the difference between ``/var/log`` and ``/tmp``?

Ans: ``/var/log`` stores persistent system and application log files, while ``/tmp`` is a temporary directory used for short-lived files that are often cleared on reboot.

Example: Attackers sometimes drop malicious payloads in ``/tmp`` because it's writable and temporary.

Q115. What are the phases of Incident Response?

Ans: The phases are Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned.

Example: After detecting ransomware (Identification), the host is isolated (Containment) before removing the malware (Eradication).

Q116. What is containment?

Ans: Containment is the process of limiting the spread and impact of an incident by isolating affected systems.

Example: Disconnecting an infected workstation from the network to stop malware from spreading.

Q117. What is the difference between containment and eradication?

Ans: Containment stops the threat from spreading further, while eradication removes the root cause of the threat from the environment entirely.

Example: Containment isolates the infected host; eradication removes the malware and closes the vulnerability that allowed entry.

Q118. Why is isolation important?

Ans: Isolation prevents an attacker or malware from moving laterally to other systems, limiting the overall damage of an incident.

Example: Isolating a compromised server prevents ransomware from spreading to file shares.

Q119. What is the MITRE ATT&CK Framework?

Ans: MITRE ATT&CK is a knowledge base of adversary tactics and techniques based on real-world observations, used to understand attacker behavior and improve detection.

Example: Mapping a phishing attack to the 'Initial Access' tactic and 'Phishing' technique (T1566).

Q120. What is the difference between tactics and techniques?

Ans: Tactics represent the attacker's overall goal (the why), while techniques represent the specific method used to achieve that goal (the how).

Example: 'Privilege Escalation' is a tactic; 'Exploitation for Privilege Escalation' is a technique used to achieve it.

Q121. What is the difference between SIEM and SOAR?

Ans: SIEM collects, correlates, and alerts on log data, while SOAR automates and orchestrates the response actions after an alert is generated.

Example: SIEM detects a phishing alert; SOAR automatically isolates the affected mailbox and blocks the sender.

Q122. What is a playbook?

Ans: A playbook is a documented, step-by-step procedure that analysts follow to investigate and respond to a specific type of incident consistently.

Example: A ransomware playbook outlining isolation, evidence collection, and recovery steps.

Q123. What is the TCP three-way handshake?

Ans: The TCP three-way handshake is the process of establishing a connection using SYN, SYN-ACK, and ACK packets between client and server.

Example: A browser sends SYN, the server replies SYN-ACK, and the browser completes with ACK to start a TCP session.

Q124. What is a SYN Flood attack?

Ans: A SYN Flood is a DoS attack where an attacker sends many SYN requests without completing the handshake, exhausting server resources.

Example: Flooding a web server with thousands of incomplete TCP connections to make it unresponsive.

Q125. What is DNS and how does it work?

Ans: DNS (Domain Name System) translates human-readable domain names into IP addresses by querying a hierarchy of DNS servers.

Example: Typing google.com resolves to its IP address through a DNS lookup.

Q126. What is the difference between TCP and UDP?

Ans: TCP is connection-oriented and reliable with error-checking and retransmission, while UDP is connectionless and faster but does not guarantee delivery.

Example: TCP is used for web browsing and email; UDP is used for video streaming and DNS queries.

Q127. What is NAT?

Ans: NAT (Network Address Translation) translates private internal IP addresses to a public IP address for internet communication.

Example: A home router using NAT so multiple devices share one public IP.

Q128. What is the difference between public and private IP addresses?

Ans: Public IPs are routable on the internet and unique globally, while private IPs are used within internal networks and are not routable on the internet.

Example: 192.168.1.10 is a private IP; 8.8.8.8 is a public IP.

Q129. What is a subnet mask?

Ans: A subnet mask defines which portion of an IP address represents the network and which represents the host.

Example: 255.255.255.0 means the first three octets identify the network.

Q130. What is port scanning?

Ans: Port scanning is the technique of probing a system to discover open ports and the services running on them.

Example: An attacker scans a server to find an open RDP port (3389) to target.

Q131. What is DNS tunneling?

Ans: DNS tunneling is a technique that encodes data within DNS queries and responses to exfiltrate data or establish covert command-and-control channels.

Example: Malware sending stolen data encoded in subdomains of DNS queries to bypass firewalls.

Q132. What is ICMP?

Ans: ICMP (Internet Control Message Protocol) is used for network diagnostics and error reporting, such as the ping command.

Example: Using 'ping' to check if a host is reachable, which relies on ICMP echo requests.

Q133. What is a VPN?

Ans: A VPN (Virtual Private Network) creates an encrypted tunnel over the internet, allowing secure remote access to a private network.

Example: An employee connecting to the company VPN to access internal resources securely from home.

Q134. What is the role of a SOC Analyst?

Ans: A SOC Analyst monitors security alerts, investigates suspicious activity, performs triage, and escalates confirmed incidents while following established procedures.

Example: Reviewing a SIEM dashboard and investigating a spike in failed login attempts.

Q135. What is alert triage?

Ans: Alert triage is the process of quickly reviewing and categorizing alerts to determine their severity and whether they require further investigation.

Example: Sorting alerts into critical, high, medium, and low priority based on initial assessment.

Q136. What is a false positive?

Ans: A false positive is an alert that indicates malicious activity but is actually benign and harmless.

Example: A vulnerability scanner triggering an IDS alert during authorized scanning.

Q137. What is a false negative?

Ans: A false negative is a real threat that goes undetected by security controls and produces no alert.

Example: A new malware variant bypassing antivirus signatures undetected.

Q138. Which is more dangerous: a false positive or a false negative?

Ans: A false negative is generally more dangerous because a real threat goes unnoticed and unaddressed, while a false positive only wastes analyst time.

Example: A missed ransomware infection (false negative) causes far more damage than an unnecessary alert investigation.

Q139. What is a SIEM?

Ans: A SIEM (Security Information and Event Management) system aggregates, correlates, and analyzes log data from across an organization to detect and alert on security events.

Example: Splunk collecting firewall, server, and endpoint logs into a single dashboard.

Q140. What is log aggregation?

Ans: Log aggregation is the process of collecting logs from multiple sources into a centralized system for easier analysis and correlation.

Example: Forwarding logs from firewalls, servers, and applications into a single SIEM platform.

Q141. How does a SIEM help security teams?

Ans: A SIEM helps by centralizing visibility, correlating events across sources, generating alerts on suspicious patterns, and supporting faster investigation and reporting.

Example: A SIEM correlating a phishing email log with a subsequent malware download alert from the same user.

Q142. What is a correlation rule?

Ans: A correlation rule is a logical condition within a SIEM that triggers an alert when a specific combination or sequence of events occurs.

Example: A rule alerting when the same user account logs in from two different countries within an hour.

Q143. How would you investigate a suspicious login alert?

Ans: Investigation includes checking the source IP and geolocation, verifying if it matches the user's normal behavior, checking for prior failed attempts, reviewing the device used, and confirming with the user if needed.

Example: Confirming a login from an unfamiliar country wasn't the legitimate user traveling, then resetting credentials if confirmed malicious.

Q144. What is Event ID 4624?

Ans: Event ID 4624 indicates a successful logon to a Windows system.

Example: Reviewing 4624 events to confirm what time and from where a user logged in.

Q145. What is Event ID 4625?

Ans: Event ID 4625 indicates a failed logon attempt on a Windows system.

Example: Multiple 4625 events from the same source in a short time may indicate a brute-force attempt.

Q146. What is Event ID 4688?

Ans: Event ID 4688 logs the creation of a new process on a Windows system.

Example: Reviewing 4688 events to detect a suspicious process like powershell.exe spawned by Word.

Q147. What is Event ID 7045?

Ans: Event ID 7045 indicates that a new service was installed on a Windows system, which attackers often use for persistence.

Example: An unexpected service installation right after a phishing email was opened.

Q148. How can PowerShell be abused by attackers?

Ans: Attackers use PowerShell for fileless malware execution, downloading payloads, credential theft, and lateral movement since it's trusted and built into Windows.

Example: An attacker using an obfuscated PowerShell command to download and execute a payload directly in memory.

Q149. What Windows logs should a SOC analyst monitor daily?

Ans: Analysts should monitor Security logs (logons, account changes), System logs (service changes), and Application logs, focusing on Event IDs like 4624, 4625, 4720, 4688, and 7045.

Example: *Reviewing daily logon failures and new service installations across critical servers.*

Q150. What Linux logs should a SOC analyst monitor daily?

Ans: Key logs include /var/log/auth.log or /var/log/secure (authentication), /var/log/syslog (system events), and application-specific logs.

Example: *Checking /var/log/auth.log for repeated SSH login failures.*

Q151. What is the purpose of the `/tmp` directory in Linux?

Ans: The `/tmp` directory stores temporary files used by applications and processes, and is typically world-writable and cleared periodically.

Example: *Malware sometimes drops payloads in `/tmp` to execute since the directory allows write access.*

Q152. What command is used to monitor logs continuously in Linux?

Ans: The `tail -f` command is used to monitor a log file continuously in real time.

Example: *Running 'tail -f /var/log/auth.log' to watch live authentication attempts.*

Q153. What command shows running processes in Linux?

Ans: The `ps aux` or `top` command shows currently running processes on a Linux system.

Example: *Using 'ps aux | grep suspicious_process' to check if malware is running.*

Q154. What is lateral movement?

Ans: Lateral movement is the technique attackers use to move from one compromised system to other systems within the same network.

Example: *Using stolen admin credentials to access additional servers after the initial breach.*

Q155. What is credential dumping?

Ans: Credential dumping is the process of extracting login credentials, password hashes, or tokens from a compromised system's memory or storage.

Example: *An attacker using Mimikatz to extract plaintext passwords from LSASS memory.*

Q156. What is malware persistence?

Ans: Malware persistence refers to techniques used to ensure malicious code continues running after a system reboot or user logoff.

Example: *Malware adding itself to a registry Run key or creating a scheduled task.*

Q157. What is ransomware?

Ans: Ransomware is malicious software that encrypts a victim's files and demands payment, usually in cryptocurrency, for the decryption key.

Example: *LockBit encrypting company files and demanding payment for the decryption key.*

Q158. What is an InfoStealer?

Ans: An InfoStealer is malware designed to steal sensitive information such as saved passwords, browser cookies, and cryptocurrency wallet data.

Example: *RedLine Stealer harvesting browser-saved credentials from an infected machine.*

Q159. What is a rootkit?

Ans: A rootkit is malware designed to hide its presence and maintain privileged access by modifying the operating system at a deep level.

Example: A kernel-level rootkit hiding malicious processes from Task Manager.

Q160. What is a Trojan?

Ans: A Trojan is malware disguised as legitimate software that performs malicious actions once executed.

Example: A fake invoice attachment that installs a backdoor when opened.

Q161. What is a worm?

Ans: A worm is self-replicating malware that spreads across networks without needing user interaction.

Example: WannaCry spreading automatically across unpatched systems using a network vulnerability.

Q162. What is the MITRE ATT&CK tactic for credential dumping?

Ans: Credential dumping falls under the 'Credential Access' tactic in the MITRE ATT&CK framework.

Example: Mimikatz usage is mapped to technique T1003 under Credential Access.

Q163. What MITRE ATT&CK tactic does PsExec commonly indicate?

Ans: PsExec usage is commonly associated with the 'Lateral Movement' and 'Execution' tactics.

Example: Attackers using PsExec to remotely execute commands on other systems after compromising one host.

Q164. What is threat intelligence?

Ans: Threat intelligence is curated information about known threats, attacker tactics, and indicators that helps organizations proactively defend against attacks.

Example: Subscribing to a threat feed that provides updated lists of malicious IPs and domains.

Q165. What is a YARA rule?

Ans: A YARA rule is a pattern-matching rule used to identify and classify malware based on textual or binary characteristics.

Example: A YARA rule detecting a specific string pattern unique to a known malware family.

Q166. What is command-and-control (C2) traffic?

Ans: C2 traffic is network communication between compromised systems and an attacker-controlled server used to issue commands and exfiltrate data.

Example: Malware periodically beaconing out to a remote server to receive new instructions.

Q167. What indicators suggest C2 activity?

Ans: Indicators include regular beaconing patterns, connections to newly registered domains, unusual user-agent strings, and traffic to known malicious IPs.

Example: An endpoint making periodic outbound connections to an unfamiliar domain every 60 seconds.

Q168. What evidence would you collect from a compromised host?

Ans: Evidence includes memory dumps, disk images, running process lists, network connections, registry data, and relevant log files.

Example: Capturing RAM and a disk image before powering off a compromised server for forensic analysis.

Q169. Why is RAM acquisition important?

Ans: RAM acquisition is important because volatile memory often contains evidence like running malware processes, network connections, and encryption keys that disappear once the system is powered off.

Example: Capturing RAM to recover an attacker's active PowerShell session details before shutdown.

Q170. What is the first action when a host is confirmed compromised?

Ans: The first action is typically to isolate the host from the network to contain the threat while preserving evidence for investigation.

Example: *Disconnecting network access on an infected workstation without powering it off.*

Q171. Why should evidence be preserved during an investigation?

Ans: Evidence must be preserved to maintain its integrity for accurate analysis and to support any legal or compliance requirements.

Example: *Imaging a hard drive instead of working directly on the original to avoid altering evidence.*

Q172. What is chain of custody?

Ans: Chain of custody is the documented process tracking who handled evidence, when, and how, ensuring it remains untampered and admissible.

Example: *Logging every person who accessed a forensic disk image from collection to analysis.*

Q173. What is a phishing attack?

Ans: A phishing attack is a social engineering technique that uses deceptive emails or messages to trick users into revealing credentials or installing malware.

Example: *An email impersonating a bank asking the user to 'verify' their account via a fake link.*

Q174. How would you investigate a phishing email?

Ans: Investigation includes checking the sender's domain, header analysis, URL/attachment analysis in a sandbox, and checking if other users received the same email.

Example: *Analyzing email headers to confirm the sender domain was spoofed.*

Q175. What is a SOAR platform?

Ans: A SOAR (Security Orchestration, Automation and Response) platform automates repetitive response tasks and orchestrates actions across multiple security tools.

Example: *SOAR automatically blocking a malicious IP across the firewall after a confirmed alert.*

Q176. How does SOAR complement SIEM?

Ans: SOAR takes the alerts generated by SIEM and automates the investigation and response workflow, reducing manual effort and response time.

Example: *SIEM detects a malware alert; SOAR automatically isolates the host and notifies the analyst.*

Q177. What is an incident response playbook?

Ans: An incident response playbook is a predefined set of steps analysts follow to handle a specific type of security incident consistently and efficiently.

Example: *A malware infection playbook detailing isolation, scanning, and remediation steps.*

Q178. What is threat hunting?

Ans: Threat hunting is a proactive approach where analysts actively search for hidden threats that have evaded existing detection mechanisms.

Example: *Searching logs for unusual PowerShell execution patterns not flagged by existing alerts.*

Q179. What logs would you review if a Domain Admin account was compromised?

Ans: Logs to review include authentication logs (4624/4625), account management events (4720/4732), process creation logs (4688), and any lateral movement indicators across servers.

Example: *Checking which systems the compromised Domain Admin account logged into after the suspected compromise time.*

Q180. How would you detect a brute-force attack?

Ans: Brute-force attacks are detected by monitoring for multiple failed login attempts from the same source within a short time window, often followed by a success.

Example: A SIEM alert triggering after 10+ failed RDP logins within 5 minutes from one IP.

Q181. What indicators suggest DNS tunneling?

Ans: Indicators include unusually long or high-entropy subdomain names, high volume of DNS queries to a single domain, and queries to recently registered domains.

Example: An endpoint generating thousands of DNS requests with random-looking subdomains to one domain.

Q182. What is the difference between detection and response?

Ans: Detection is identifying that malicious activity is occurring, while response is the set of actions taken to contain, eliminate, and recover from it.

Example: Detection: alert fires on suspicious file execution. Response: isolating the host and removing the file.

Q183. What is the purpose of File Integrity Monitoring (FIM)?

Ans: FIM monitors critical files and directories for unauthorized changes, helping detect tampering, malware installation, or configuration drift.

Example: FIM alerting when an attacker modifies a system binary to maintain persistence.

Q184. How does Wazuh help in SOC operations?

Ans: Wazuh provides log analysis, file integrity monitoring, intrusion detection, vulnerability detection, and compliance monitoring, centralizing visibility for SOC analysts.

Example: Wazuh agents forwarding endpoint logs to the manager, which applies rules to detect suspicious activity.

Q185. What are Wazuh agents?

Ans: Wazuh agents are lightweight programs installed on endpoints that collect logs, monitor file integrity, and send data to the Wazuh manager for analysis.

Example: An agent installed on a Windows server forwarding Security event logs to the Wazuh manager.

Q186. What are Wazuh decoders and rules?

Ans: Decoders parse raw log data into structured fields, while rules define the logic that triggers alerts based on those parsed fields.

Example: A custom decoder parsing a web shell log entry, with a rule that triggers an alert when that pattern is matched.

Q187. What is Sysmon?

Ans: Sysmon (System Monitor) is a Windows tool that provides detailed logging of process creation, network connections, and file changes beyond default Windows logs.

Example: Sysmon logging a suspicious child process spawned from a Word document (Event ID 1).

Q188. Why is Sysmon useful for SOC analysts?

Ans: Sysmon provides much richer, more granular visibility into system activity than default Windows logs, making it easier to detect malicious behavior like process injection or unusual network connections.

Example: Using Sysmon Event ID 3 to detect a process making an unexpected outbound network connection.

Q189. What is Event ID 1102?

Ans: Event ID 1102 indicates that the Windows Security audit log was cleared, often an indicator of an attacker covering their tracks.

Example: An unexpected 1102 event right before other malicious activity stops appearing in logs is a major red flag.

Q190. What is Event ID 4720?

Ans: Event ID 4720 logs the creation of a new user account on a Windows system.

Example: A 4720 event for an account created outside business hours by an unexpected admin.

Q191. What is Event ID 4732?

Ans: Event ID 4732 logs when a member is added to a security-enabled local group.

Example: A standard user account being added to the local Administrators group unexpectedly.

Q192. What is Event ID 4726?

Ans: Event ID 4726 logs the deletion of a user account on a Windows system.

Example: An attacker deleting a temporary account they created to cover their tracks.

Q193. How do attackers maintain persistence on Windows?

Ans: Attackers maintain persistence using registry Run keys, scheduled tasks, services, startup folder entries, and WMI event subscriptions.

Example: Malware creating a scheduled task that re-executes the payload every login.

Q194. What is privilege escalation?

Ans: Privilege escalation is the process of gaining higher-level permissions than originally granted, allowing greater control over a system.

Example: Exploiting an unpatched vulnerability to gain SYSTEM-level access from a standard user account.

Q195. What is the difference between IOC and IOA?

Ans: An IOC (Indicator of Compromise) is evidence that an attack has already occurred, while an IOA (Indicator of Attack) focuses on the behavior and intent indicating an attack in progress.

Example: A malicious file hash is an IOC; unusual process behavior suggesting active exploitation is an IOA.

Q196. What is data exfiltration?

Ans: Data exfiltration is the unauthorized transfer of sensitive data out of an organization's network to an external location controlled by an attacker.

Example: An attacker compressing and uploading customer data to an external FTP server.

Q197. What are common indicators of malware infection?

Ans: Common indicators include unusual outbound traffic, unexpected new processes, high CPU/disk usage, disabled security tools, and unfamiliar scheduled tasks or services.

Example: A workstation suddenly showing high CPU usage along with an unrecognized process making outbound connections.

Q198. How would you investigate unusual outbound traffic?

Ans: Investigation includes identifying the destination IP/domain reputation, the process responsible for the connection, the data volume transferred, and whether the pattern matches known C2 behavior.

Example: Tracing unusual traffic back to an unsigned executable beaconing to a newly registered domain.

Q199. What is analyst fatigue and how can it be reduced?

Ans: Analyst fatigue (alert fatigue) results from handling a high volume of alerts, especially false positives, leading to reduced focus and missed threats. It can be reduced through better tuning, automation, and prioritization.

Example: *Tuning out noisy, low-value alerts and using SOAR automation for repetitive triage tasks reduces fatigue.*

Q200. Why do you want to become a SOC Analyst?

Ans: This is a personal/motivational question — a strong answer connects genuine interest in cybersecurity, hands-on skills built through labs and certifications, and a desire to protect organizations from real-world threats.

Example: *Mentioning hands-on practice with SIEM tools, vulnerability management, and a genuine interest in defending systems against attackers.*

★Keep Learning, Stay Curious, and Protect the Digital World! 😊